FTPVM Host Security Assessment and Vulnerability Analysis Report

Prepared by
Hamma Jaff

Environment	**Controlled cybersecurity lab environment**
Primary tools	**Hydra, Nmap, Nikto, FlareVM**
Target host	**FTPVM at 192.168.0.8**
Assessment focus	**Authentication weakness, service exposure, web server security, and compromise indicators**

Executive Summary

This report presents the results of a security assessment conducted against an FTP server hosted within a virtual machine environment identified as FTPVM at 192.168.0.8. The assessment evaluated exposed services, insecure configurations, authentication weaknesses, and indicators of potential system compromise using Hydra, Nmap, Nikto, and FlareVM.

The testing identified multiple high-risk issues, including anonymous FTP access, weak password controls, outdated Windows XP and IIS services, dangerous HTTP methods, insecure cookie settings, exposed Windows networking services, possible remote access services, and evidence consistent with backdoor or command-and-control functionality. The assessment also demonstrated successful anonymous access to server files and successful brute-force password recovery attempts.

Overall, the host was found to operate in a high-risk state with significant exposure to unauthorized access, denial-of-service conditions, exploitation of legacy Microsoft vulnerabilities, and potential post-compromise activity. Immediate remediation is recommended, including service hardening, patching, removal of obsolete components, elimination of anonymous access, and full incident-response review.

Introduction

This assessment was performed to evaluate the security posture of the FTPVM host located at 192.168.0.8 within a controlled cybersecurity lab environment. The analysis focused on identifying exposed services, insecure authentication practices, web server vulnerabilities, and indicators of broader system compromise. The target was assessed using a combination of network scanning, service enumeration, brute-force testing, and direct FTP interaction.

The tools used during the assessment included Hydra for password attack simulation, Nmap for host and service enumeration, Nikto for web server analysis, and FlareVM for direct interaction with the FTP service. Together, these tools provided both network-level and application-level visibility into the host's security weaknesses.

Scope

The scope of this assessment was limited to analysis of the FTPVM host at 192.168.0.8. Activities included FTP authentication testing, anonymous access validation, directory and file exposure review, network service enumeration, vulnerability script analysis, web server configuration review, and validation of upload and download permissions through FTP interaction.

The assessment was conducted in an authorized lab setting for controlled security analysis and documentation purposes.

Methodology

The assessment followed a staged methodology to identify host weaknesses and validate security findings. Hydra was used to test password resilience against the FTP service through automated brute-force attempts. Nmap was then used in multiple phases, including banner enumeration, vulnerability script execution, and full TCP port scanning with service and version detection. Nikto was used to evaluate the exposed HTTP service for insecure methods, outdated components, and missing security controls. Finally, FlareVM was used to

establish direct FTP interaction in order to validate anonymous access, file listing, file download, and file upload capabilities.

This methodology allowed the assessment to move from passive enumeration to active validation of exposure and operational risk.

Assessment Snapshot

Area	Tool	Key result	Risk
Authentication	Hydra	Successful password-based access attempt demonstrated weak credential resilience.	**High**
FTP exposure	Kali FTP / FlareVM	Anonymous login, file listing, download, and upload were accepted.	**Critical**
Platform enumeration	Nmap banner scan	Windows XP, Microsoft FTP Service, IIS 5.1, SMTP, and SMB-related services were exposed.	**Critical**
Vulnerability analysis	Nmap vuln scripts	Slowloris exposure, TRACE enabled, missing HttpOnly flag, and legacy Microsoft weaknesses identified.	**Critical**
Full host scan	Nmap -sC -sV -p-	Additional services included VNC, IRC, and a probable bind shell.	**Critical**
Web analysis	Nikto	Risky HTTP methods, WebDAV, legacy FrontPage components, and missing security headers were reported.	**High**

Findings and Analysis

1. FTP Authentication Weakness and Brute-Force Exposure

Hydra testing against the FTP service revealed that the target was susceptible to password-based attack activity. The use of a common password wordlist resulted in at least one successful credential discovery, indicating weak password controls and a lack of effective brute-force defenses such as rate limiting, lockout controls, or alerting mechanisms.

This finding suggests that the server's authentication controls are insufficient to resist basic automated password attacks. In a real environment, this weakness could allow attackers to gain access through credential guessing without requiring advanced exploitation.

2. Anonymous FTP Access and File Exposure

Direct interaction with the FTP service confirmed that anonymous login was enabled. After connecting to the FTP server, directory contents were exposed without meaningful authentication, including files such as

lock.bat, nc.exe, Razor.1911.IRC.nfo, and a VNC4 directory. The availability of tools such as nc.exe is especially concerning because such utilities are commonly associated with unauthorized remote access, lateral movement, or post-exploitation activity.

Anonymous access to these files represents a serious access control failure. The ability to view and retrieve executables and related content without authorization significantly increases the risk of data leakage, misuse of tools, and discovery of operational artifacts that could support further compromise.

3. Banner Enumeration and Legacy Platform Exposure

Nmap banner analysis identified the target as running Windows XP with Microsoft FTP Service and Microsoft IIS services. This is a critical finding because Windows XP is obsolete, unsupported, and associated with numerous severe and well-documented vulnerabilities. Open services identified on ports such as 21 and 80 indicate that the host is exposed both as an FTP server and as a web server.

The assessment also indicates likely exposure to major Microsoft vulnerabilities including MS08-067 and MS17-010, both of which are associated with remote code execution and are commonly used in real-world attacks. Legacy platform exposure substantially increases the likelihood that attackers can obtain unauthorized access through known exploit paths.

4. Nmap Vulnerability Script Findings

The vulnerability scan identified numerous services exposed on the host, including FTP, SMTP, HTTP, Windows RPC services, NetBIOS and SMB services, a possible HTTPS service, IRC-related services, and UPnP-related exposure. The scan findings also showed high-risk issues including likely exposure to MS08-067, likely exposure to MS17-010 / EternalBlue, Slowloris denial-of-service exposure on the HTTP service, enabled HTTP TRACE, missing HttpOnly cookie protections, and unnecessary or unidentified services increasing the attack surface.

These findings show that the host is not only outdated, but also broadly exposed and insufficiently hardened. The service profile suggests a system with expanded attack surface and weak defensive configuration.

5. FTP Interaction and Write Access Validation Using FlareVM

Using FlareVM, the FTP service was tested directly to validate access control and file transfer behavior. Anonymous authentication was accepted without restriction. Directory enumeration exposed multiple files, and download activity was successful. A file upload test also succeeded after correcting the local file path.

The ability to upload files anonymously is a severe security issue. A system that allows unrestricted file placement can be used to stage malicious tools, deliver malware, store illicit content, or support persistence and lateral movement. Combined with open FTP access, this represents a major operational risk.

6. Full TCP Port Scan Findings

A full TCP scan with nmap -sC -sV -p- 192.168.0.8 identified additional high-risk services beyond the initial scan set. The host exposed anonymous FTP, SMTP with NTLM-related disclosure, IIS 5.1 with TRACE, COPY, and WebDAV exposure, Windows networking services, IRC services, VNC services on 5800 and 5900, and a probable bind shell on port 6666.

The bind shell finding is especially severe because it strongly suggests prior compromise or unauthorized remote shell capability. Combined with open VNC and IRC services, the host profile is consistent with a system that may already have been used for malicious control or backdoor access.

7. Web Server Security Analysis with Nikto

Nikto analysis of the HTTP service identified a number of serious issues: outdated Microsoft-IIS/5.1, cookies set without HttpOnly, missing X-Frame-Options, missing X-Content-Type-Options, dangerous HTTP methods including DELETE, PUT, and MOVE, WebDAV functionality, possible internal IP leakage through PROPFIND, the presence of Microsoft TSAC and FrontPage extensions, and default files or directories that expose server details.

These findings indicate a web service in a highly insecure state. The combination of dangerous methods, outdated components, weak header configuration, and legacy IIS deployment significantly increases exposure to web-based attack activity, unauthorized file operations, and information disclosure.

Recommendations

- Disable anonymous FTP access immediately.
- Require strong authenticated access for all FTP operations.
- Remove or strictly restrict upload permissions.
- Decommission or upgrade the Windows XP host and all legacy IIS/FTP components.
- Patch known Microsoft vulnerabilities, especially exposure associated with MS08-067 and MS17-010.
- Disable dangerous HTTP methods such as TRACE, PUT, DELETE, MOVE, and unnecessary WebDAV functionality.
- Apply secure cookie settings and implement modern security headers such as HttpOnly, Secure, X-Frame-Options, and X-Content-Type-Options.
- Investigate suspicious services including the bind shell on port 6666, IRC-related services, VNC exposure, and unknown open ports.
- Review all exposed services and remove any that are not operationally required.
- Conduct a full incident-response review to determine whether the host has already been compromised.

Conclusion

The FTPVM host assessment identified a combination of weak authentication controls, obsolete software, excessive service exposure, insecure web configuration, and indicators of possible compromise. Anonymous FTP access, successful brute-force activity, unrestricted file interaction, legacy Windows and IIS components, and the detection of a probable bind shell together indicate that the host is operating with a very high level of security risk.

Immediate remediation is required to reduce the likelihood of exploitation, unauthorized access, and further compromise. Priority actions should include disabling anonymous access, removing unnecessary services, patching or replacing obsolete systems, and performing a full review for persistence mechanisms or attacker activity. The findings reinforce the importance of service hardening, patch management, strong authentication, and continuous monitoring in the security of exposed hosts.

Appendix A: Assessment Evidence

The following figures document key assessment activities including anonymous FTP access, service enumeration, vulnerability script output, and direct validation of file transfer exposure.

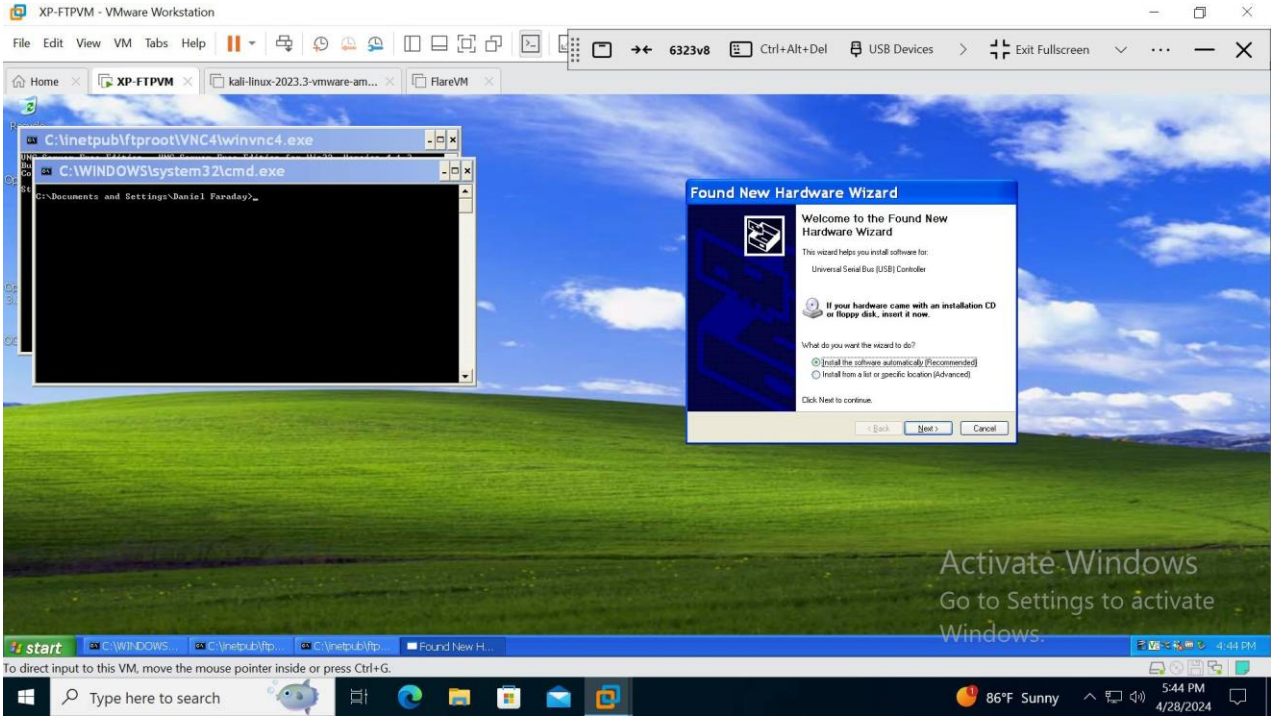
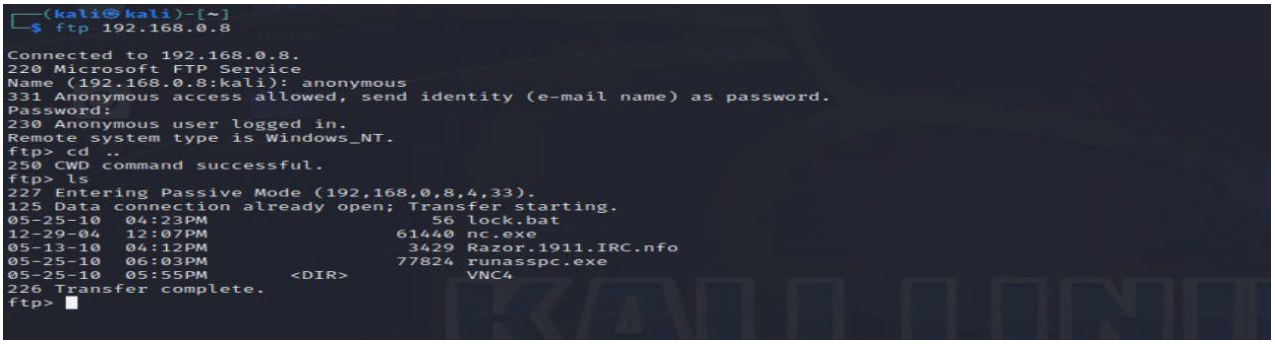


Figure A1. Host desktop evidence showing legacy Windows XP context and the presence of command-line and VNC-related executables on the FTPVM system.



```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.0.8

Connected to 192.168.0.8.
220 Microsoft FTP Service
Name (192.168.0.8:kali): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 Anonymous user logged in.
Remote system type is Windows_NT.
ftp> cd ..
250 CWD command successful.
ftp> ls
227 Entering Passive Mode (192,168,0,8,4,33).
125 Data connection already open; Transfer starting.
05-25-10  04:23PM                   56 lock.bat
12-29-04  12:07PM                61440 nc.exe
05-13-10  04:12PM                 3429 Razor.1911.IRC.nfo
05-25-10  06:03PM                77824 runasspc.exe
05-25-10  05:55PM       <DIR>          VNC4
226 Transfer complete.
ftp>
```

Figure A2. Anonymous FTP login from the Kali assessment host showing unauthenticated directory listing and exposed files including nc.exe and Razor.1911.IRC.nfo.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV --script=banner 192.168.0.8
Starting Nmap 7.94 ( https://nmap.org ) at 2024-04-24 18:21 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.0.8
Host is up (0.018s latency).
Not shown: 988 closed tcp ports (conn-refused)
PORT     STATE SERVICE      VERSION
21/tcp   open  ftp          Microsoft ftpd
|_banner: 220 Microsoft FTP Service
25/tcp   open  smtp         Microsoft ESMTP 6.0.2600.1
| banner: 220 Faraday Microsoft ESMTP MAIL Service, Version: 6.0.2600.1 r
|_eady at  Wed, 24 Apr 2024 16:23:51 -0600
80/tcp   open  http         Microsoft IIS httpd 5.1
|_http-server-header: Microsoft-IIS/5.1
135/tcp  open  msrpc        Microsoft Windows RPC
139/tcp  open  netbios-ssn  Microsoft Windows netbios-ssn
443/tcp  open  https?
445/tcp  open  microsoft-ds Microsoft Windows XP microsoft-ds
666/tcp  open  tcpwrapped
1025/tcp open  msrpc        Microsoft Windows RPC
1029/tcp open  msrpc        Microsoft Windows RPC
5000/tcp open  upnp?
| fingerprint-strings:
|   FourOhFourRequest, GenericLines, GetRequest, HTTPOptions, RTSPRequest, SIPOptions:
|_    HTTP/1.1 400 Bad Request
6667/tcp open  irc
|_banner: NOTICE AUTH :*** Checking Ident
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.
cgi?new-service :
SF-Port5000-TCP:V=7.94%I=7%D=4/24%Time=662985FD%P=x86_64-pc-linux-gnu%r(Ge
SF:nericLines,1C,"HTTP/1\.1\x20400\x20Bad\x20Request\r\n\r\n")%r(GetReques
SF:t,1C,"HTTP/1\.1\x20400\x20Bad\x20Request\r\n\r\n")%r(RTSPRequest,1C,"HT
SF:TP/1\.1\x20400\x20Bad\x20Request\r\n\r\n")%r(HTTPOptions,1C,"HTTP/1\.1\
SF:x20400\x20Bad\x20Request\r\n\r\n")%r(FourOhFourRequest,1C,"HTTP/1\.1\x2
SF:0400\x20Bad\x20Request\r\n\r\n")%r(SIPOptions,1C,"HTTP/1\.1\x20400\x20B
SF:ad\x20Request\r\n\r\n");
Service Info: Host: faraday; OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 145.36 seconds

┌──(kali㉿kali)-[~]
└─$
```

Figure A3. Nmap banner scan identifying Microsoft FTP Service, Microsoft ESMTP, IIS 5.1, Windows XP, and multiple exposed network services on the target host.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV --script=vuln 192.168.0.8
Starting Nmap 7.94 ( https://nmap.org ) at 2024-04-24 18:36 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.0.8
Host is up (0.021s latency).
Not shown: 987 closed tcp ports (conn-refused)
PORT     STATE SERVICE      VERSION
21/tcp   open  ftp          Microsoft ftpd
25/tcp   open  smtp         Microsoft ESMTP 6.0.2600.1
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
80/tcp   open  http         Microsoft IIS httpd 5.1
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
| http-enum:
|   /tsweb/: Remote Desktop Web Connection
|   /postinfo.html: Frontpage file or folder
|   /_vti_bin/fpcount.exe?Page=default.asp|Image=3: Frontpage file or folder
|   /_vti_bin/shtml.dll: Frontpage file or folder
|   /_vti_bin/shtml.exe: Frontpage file or folder
|_  /printers/: Potentially interesting folder (401 Access Denied)
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2007-6750
|       Slowloris tries to keep many connections to the target web server open and hold
|       them open as long as possible.  It accomplishes this by opening connections to
|       the target web server and sending a partial request. By doing so, it starves
|       the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_      http://ha.ckers.org/slowloris/
|_http-trace: TRACE is enabled
| http-cookie-flags:
|   /:
|     ASPSESSIONIDQQQQGAOU:
|_      httponly flag not set
|_http-server-header: Microsoft-IIS/5.1
139/tcp  open  msrpc        Microsoft Windows RPC
139/tcp  open  netbios-ssn  Microsoft Windows netbios-ssn
```

Figure A4. Nmap vulnerability-script output showing Slowloris exposure, enabled TRACE, missing HttpOnly cookie protections, and legacy web application artifacts.

```
443/tcp  open  https?
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_ssl-ccs-injection: No reply from server (TIMEOUT)
|_http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
|_http-vuln-cve2014-3704: ERROR: Script execution failed (use -d to debug)
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
445/tcp  open  microsoft-ds Microsoft Windows XP microsoft-ds
666/tcp  open  doom?
| fingerprint-strings:
|   GenericLines, NULL:
|     :Oqy
|_    d=~XH
1025/tcp open  msrpc        Microsoft Windows RPC
1029/tcp open  msrpc        Microsoft Windows RPC
1100/tcp open  msrpc        Microsoft Windows RPC
5000/tcp open  upnp?
| fingerprint-strings:
|   FourOhFourRequest, GenericLines, GetRequest, HTTPOptions, RTSPRequest, SIPOptions:
|_    HTTP/1.1 400 Bad Request
6667/tcp open  irc
| irc-botnet-channels:
|_  ERROR: TIMEOUT
|_irc-unrealircd-backdoor: Server closed connection, possibly due to too many reconnects. Try again with argument irc-unrealircd-backdoor.wait set to 100 (
or higher if you get this message again).
2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submi
t.cgi?new-service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port666-TCP:V=7.94%I=7%D=4/24%Time=6629897F%P=x86_64-pc-linux-gnu%r(NUL
SF:L,B4,"\xed\xb9\xed\xdd\xd0\x81\xaf8\n\xea%\xf6:Oqy\xdb,\x9c\xd6o\x85\x
SF:16o*\x8e\x10Jg\xd9\x14\x9bR\x07\x8do>\xafb\xba\x85uA\xc9\xbdO9o\x93\x01
SF:\xb8\xd5\xc1\x80\x9f\xa2XS\xe3\xec\x97\x1fl\xf6\xc2>\xd3;\xbb\xcd\x82\x
SF:e5\x13\xbb\x87\xcf\x8dD\xd7x\xe4gz\xde\xde\xb1Uj\xab\xbc\x9f\xa3X\xc4Y\
SF:xb0\x11\xe6\x94\x15\x10\xa0\xec\x7f\xcaXM\xbd\xde\x8a\xf5\xae0#\xda\xba
SF:\x8fN\xdb<\xde\xcbK\x8d\x84\x19K\x94R\x05w\x19d=\"XH\xcb\xber'\xc9w\xca
SF:t\xf2\xbb\xa6\xe5>:\xb5\x7f\x8d\xaf\x1e\x8a,0,\xf4B\x94rg\xf0q\xc2@@\xb
SF:c5\x85w\x1aL\x9f\?\xbc\x0b")%r(GenericLines,B4,"\xed\xb9s\xed\xdd\xd0\x
SF:81\xaf#\n\xea%\xf6:Oqy\xdb,\x9c\xd6o\x85\x16\*\x8e\x10Jg\xd9\x14\x9bR\x
SF:07\x8do>\xafb\xba\x85uA\xc9\xbdO9o\x93\x01\xb8\xd5\xc1\x80\x9f\xa2XS\xe
SF:3\xec\x97\x1fl\xf6\xc2>\xd3;\xbb\xcd\x82\xe5\x13\xbb\x87\xcf\x8dD\xd7\
SF:xe4gz\xde\xde\xb1Uj\xab\xbc\x9f\xa3X\xc4Y\xba\x11\xe6\x94\x15\x10\xaa\x
SF:ae\x7f\xcaXM\xbd\xde\x8a\xf5\xae0#\xda\xba\x8fN\xdb<\xde\xcbK\x8d\x84\x
SF:19K\x94R\x05w\x19d=\"XH\xcb\xber'\xc9w\xcat\xf2\xbb\xa6\xe5>:\xb5\x7f\x
SF:8d\xaf\x1e\x8a,0,\xf4B\x94rg\xf0q\xc2@@\xbc5\x85w\x1aL\x9f\?\xbc\x0b");
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
```

Figure A5. Nmap vulnerability-script continuation showing additional service exposure, suspicious ports, and legacy Windows networking services.

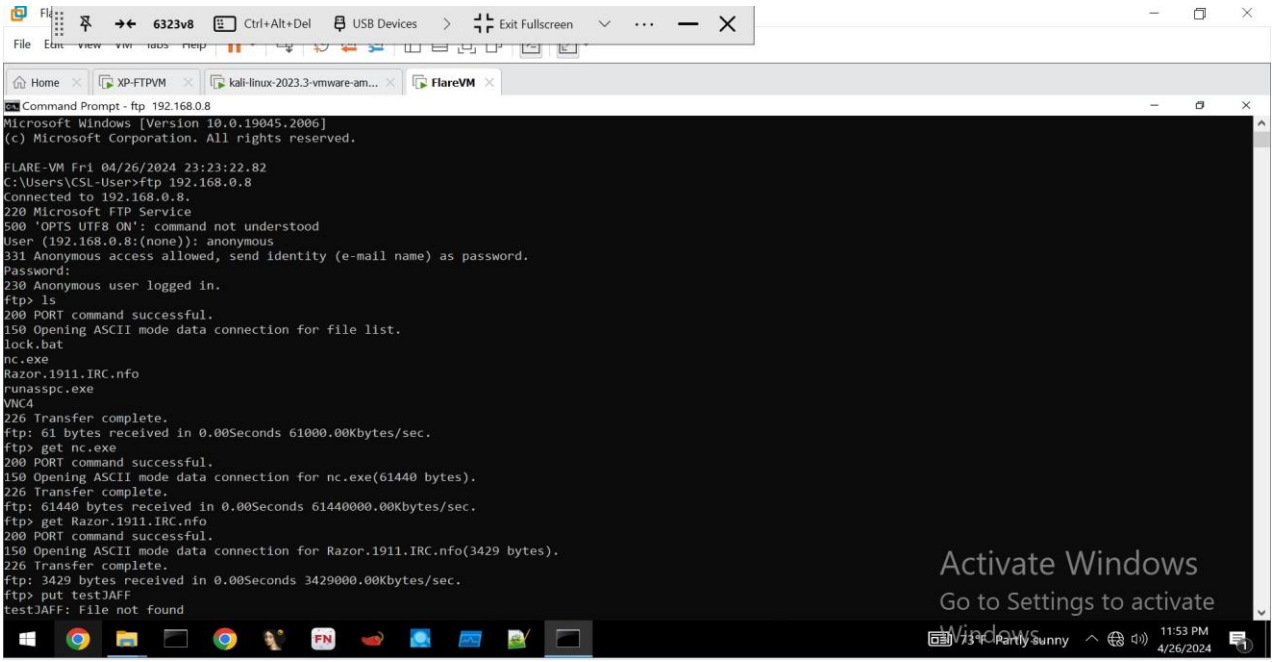


Figure A6. FlareVM session demonstrating anonymous FTP access, file listing, and successful download of exposed server files.

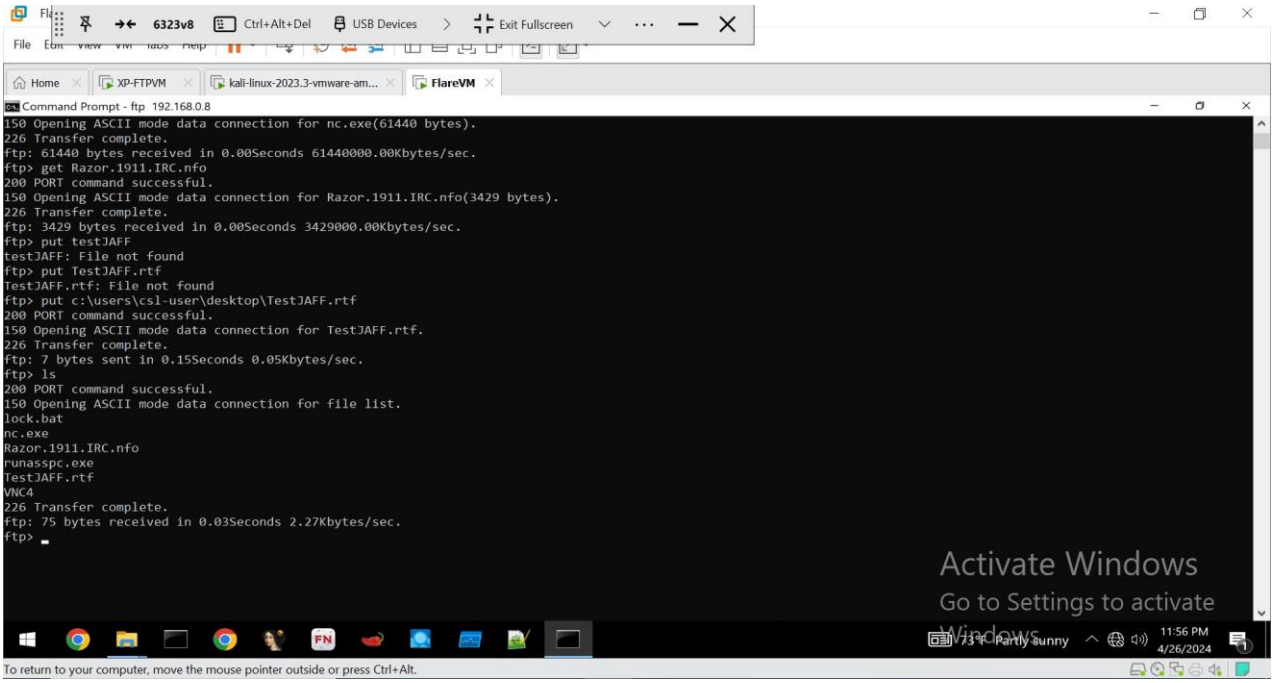


Figure A7. FlareVM session demonstrating successful anonymous upload of TestJAFF.rtf, confirming insecure write access on the FTP service.

```
kali-linux-2023.3-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Home | XP-FTPVM | kali-linux-2023.3-vmware-... | FlareVM
6323v8 | Ctrl+Alt+Del | USB Devices | Exit Fullscreen
1 2 3 4 | 22:12
kali@kali: ~
File Actions Edit View Help

┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV -p- 192.168.0.8
Starting Nmap 7.94 ( https://nmap.org ) at 2024-04-28 22:05 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.0.8
Host is up (0.023s latency).
Not shown: 65518 closed tcp ports (conn-refused)
PORT     STATE SERVICE      VERSION
21/tcp   open  ftp          Microsoft ftpd
| ftp-syst:
|   SYST: Windows_NT
|   STAT:
| Microsoft FTP Service status:
|      Connected to 192.168.0.6
|      Logged in as IEUser@
|      TYPE: ASCII, FORM: Nonprint; STRUcture: File; transfer MODE: STREAM
|      No data connection
|_End of status.
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| 05-25-10  04:23PM                   56 lock.bat
| 12-29-04  12:07PM                61440 nc.exe
| 05-13-10  04:12PM                 3429 Razor.1911.IRC.nfo
| 05-25-10  06:03PM                77824 runasspc.exe
| 04-26-24  10:49PM                    7 TestJAFF.rtf
|_05-25-10  05:55PM       <DIR>        VNC4
25/tcp   open  smtp         Microsoft ESMTP 6.0.2600.1
| smtp-commands: faraday Hello [192.168.0.6], AUTH GSSAPI NTLM LOGIN, AUTH=LOGIN, SIZE 2097152, PIPELINING, DSN, ENHANCEDSTATUSCODES, 8bitmime, BINARYMIME,
CHUNKING, VRFY, OK
|_ This server supports the following commands: HELO EHLO STARTTLS RCPT DATA RSET MAIL QUIT HELP AUTH BDAT VRFY
| smtp-ntlm-info:
|   Target_Name: FARADAY
|   NetBIOS_Domain_Name: FARADAY
|   NetBIOS_Computer_Name: FARADAY
|   DNS_Domain_Name: faraday
|_  DNS_Computer_Name: faraday
80/tcp   open  http         Microsoft IIS httpd 5.1
| http-cookie-flags:
|   /:
|     ASPSESSIONIDQGQQGMKK:
|_      httponly flag not set
|_http-title: Under Construction
| http-methods:
Activate Windows
Go to Settings to activate
Windows.
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.
```

Figure A8. Full TCP scan overview identifying anonymous FTP, SMTP, HTTP, and additional service exposure during exhaustive host enumeration.

Appendix B: Full TCP Scan and Web Analysis Evidence

These figures capture additional high-risk indicators from the full TCP scan and Nikto web analysis, including a probable bind shell, VNC exposure, risky HTTP methods, and vulnerable legacy web components.

```
|      Logged in as IEUser@
|      TYPE: ASCII, FORM: Nonprint; STRUcture: File; transfer MODE: STREAM
|      No data connection
|_End of status.
25/tcp   open  smtp         Microsoft ESMTP 6.0.2600.1
| smtp-ntlm-info:
|   Target_Name: FARADAY
|   NetBIOS_Domain_Name: FARADAY
|   NetBIOS_Computer_Name: FARADAY
|   DNS_Domain_Name: faraday
|_  DNS_Computer_Name: faraday
| smtp-commands: faraday Hello [192.168.0.6], AUTH GSSAPI NTLM LOGIN, AUTH=LOGIN, SIZE 2097152, PIPELINING, DSN, ENHANCEDSTATUSCODES, 8bitmime, BINARYMIME, CHUNKING, VRFY, OK
|_ This server supports the following commands: HELO EHLO STARTTLS RCPT DATA RSET MAIL QUIT HELP AUTH BDAT VRFY
80/tcp   open  http         Microsoft IIS httpd 5.1
| http-webdav-scan:
|   Server Type: Microsoft-IIS/5.1
|   Public Options: OPTIONS, TRACE, GET, HEAD, DELETE, PUT, POST, COPY, MOVE, MKCOL, PROPFIND, PROPPATCH, LOCK, UNLOCK, SEARCH
|   Allowed Methods: OPTIONS, TRACE, GET, HEAD, COPY, PROPFIND, SEARCH, LOCK, UNLOCK
|   WebDAV type: Unknown
|_  Server Date: Mon, 29 Apr 2024 01:09:37 GMT
|_http-server-header: Microsoft-IIS/5.1
|_http-title: Under Construction
| http-cookie-flags:
|   /:
|     ASPSESSIONIDQGQQGMKK:
|_      httponly flag not set
| http-methods:
|_  Potentially risky methods: TRACE COPY PROPFIND SEARCH LOCK UNLOCK DELETE PUT MOVE MKCOL PROPPATCH
135/tcp  open  msrpc        Microsoft Windows RPC
139/tcp  open  netbios-ssn Microsoft Windows netbios-ssn
443/tcp  open  https?
445/tcp  open               Windows XP microsoft-ds
666/tcp  open  doom?
| fingerprint-strings:
|   GenericLines, NULL:
|     :Oqy
|_      d="XH
1025/tcp open  msrpc        Microsoft Windows RPC
1029/tcp open  msrpc        Microsoft Windows RPC
4400/tcp open  irc          ircu ircd
5000/tcp open  upnp?
| fingerprint-strings:
|   FourOhFourRequest, GenericLines, GetRequest, HTTPOptions, RTSPRequest, SIPOptions:
|_    HTTP/1.1 400 Bad Request
5800/tcp open  vnc-http     RealVNC 4.0 (resolution: 400x250; VNC TCP port: 5900)
|_http-server-header: RealVNC/4.0
|_http-title: VNC viewer for Java
5900/tcp open  vnc          VNC (protocol 3.8)
| vnc-info:
|   Protocol version: 3.8
|   Security types:
|_    VNC Authentication (2)
6666/tcp open  bindshell    CMD.EXE (**BACKDOOR**; Windows 5.1.2600; path: C:\Documents and Settings\Daniel Faraday)
6667/tcp open  irc          ircu ircd
| irc-info:
|   users: 2
|   servers: 1
|   chans: 1
|   lusers: 2
|   lservers: 0
```

Figure B1. Full Nmap TCP service and version detection results showing SMTP, IIS, RPC, SMB, VNC, bind shell, and IRC-related service exposure on FTPVM.

```
6666/tcp open  bindshell   CMD.EXE (**BACKDOOR**; Windows 5.1.2600; path: C:\Documents and Settings\Daniel Faraday)
6667/tcp open  irc         ircu ircd
| irc-info:
|   users: 2
|   servers: 1
|   chans: 1
|   lusers: 2
|   lservers: 0
|_  server: my.server.name
2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port666-TCP:V=7.94%I=7%D=4/28%Time=662EF2D7%P=x86_64-pc-linux-gnu%r(NUL
SF:L,B4,"\xed\xb9s\xed\xdd\xd0\x81\xaf#\n\xea%\xf6:0qy\xdb,\x9c\xd6o\x85\x
SF:16\*\x8e\x10Jg\xd9\x14\x9bR\x07\x8do>\xafb\xba\x85uA\xc9\xbdO9o\x93\x01
SF:|\xb8\xd5\xc1\x80\x9f\xa2X5\xe3\xec\x97\x1f1\xf6\xc2>\xd3;\xbb\xcd\x82\x
SF:e5\x13\xbb\x87\xcf\x8dD\xd7x\xe4gz\xde\xde\xb1Uj\xab\xbc\x9f\xa3X\xc4Y\
SF:xba\x11\xe6\x94\x15\x10\xaa\xae\x7f\xcaXM\xbd\xde\x8a\xf5\xae0#\xda\xba
SF:|\x8fN\xdb<\xde\xcbK\x8d\x84\x19K\x94R\x05w\x19d=\"XH\xcb\xber'\xc9w\xca
SF:t\xf2\xbb\xa6\xe5>:\xb5\x7f\x8d\xaf\x1e\x8a,0,\xf4B\x94rg\xf0q\xc2@@\xb
SF:c5\x85w\x1aL\x9f\?\xbc\x0b");r(GenericLines,B4,"\xed\xb9s\xed\xdd\xd0\x
SF:81\xaf#\n\xea%\xf6:0qy\xdb,\x9c\xd6o\x85\x16\*\x8e\x10Jg\xd9\x14\x9bR\x
SF:07\x8do>\xafb\xba\x85uA\xc9\xbdO9o\x93\x01\xb8\xd5\xc1\x80\x9f\xa2X5\xe
SF:3\xec\x97\x1f1\xf6\xc2>\xd3;\xbb\xcd\x82\xe5\x13\xbb\x87\xcf\x8dD\xd7x\
SF:xe4gz\xde\xde\xb1Uj\xab\xbc\x9f\xa3X\xc4Y\xba\x11\xe6\x94\x15\x10\xaa\x
SF:ae\x7f\xcaXM\xbd\xde\x8a\xf5\xae0#\xda\xba\x8fN\xdb<\xde\xcbK\x8d\x84\x
SF:19K\x94R\x05w\x19d=\"XH\xcb\xber'\xc9w\xcat\xf2\xbb\xa6\xe5>:\xb5\x7f\x
SF:8d\xaf\x1e\x8a,0,\xf4B\x94rg\xf0q\xc2@@\xbc5\x85w\x1aL\x9f\?\xbc\x0b");
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port5000-TCP:V=7.94%I=7%D=4/28%Time=662EF2D7%P=x86_64-pc-linux-gnu%r(Ge
SF:nericLines,1C,"HTTP/1\.1\x20400\x20Bad\x20Request\r\n\r\n")%r(GetReques
SF:t,1C,"HTTP/1\.1\x20400\x20Bad\x20Request\r\n\r\n")%r(RTSPRequest,1C,"HT
SF:TP/1\.1\x20400\x20Bad\x20Request\r\n\r\n")%r(HTTPOptions,1C,"HTTP/1\.1\
SF:x20400\x20Bad\x20Request\r\n\r\n")%r(FourOhFourRequest,1C,"HTTP/1\.1\x2
SF:0400\x20Bad\x20Request\r\n\r\n")%r(SIPOptions,1C,"HTTP/1\.1\x20400\x20B
SF:ad\x20Request\r\n\r\n");
Service Info: Host: faraday; OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Host script results:
| smb-os-discovery:
|   OS: Windows XP (Windows 2000 LAN Manager)
|   OS CPE: cpe:/o:microsoft:windows_xp::-
|   Computer name: faraday
|   NetBIOS computer name: FARADAY\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2024-04-28T19:09:38-06:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 2h59m59s, deviation: 4h14m34s, median: -1s
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: FARADAY, NetBIOS user: DANIEL FARADAY, NetBIOS MAC: 00:0c:29:a2:f5:fc (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 161.72 seconds
```

Figure B2. Full TCP scan service detection results showing bind shell exposure, IRC service enumeration, SMB discovery details, and Windows XP host identification on FTPVM.

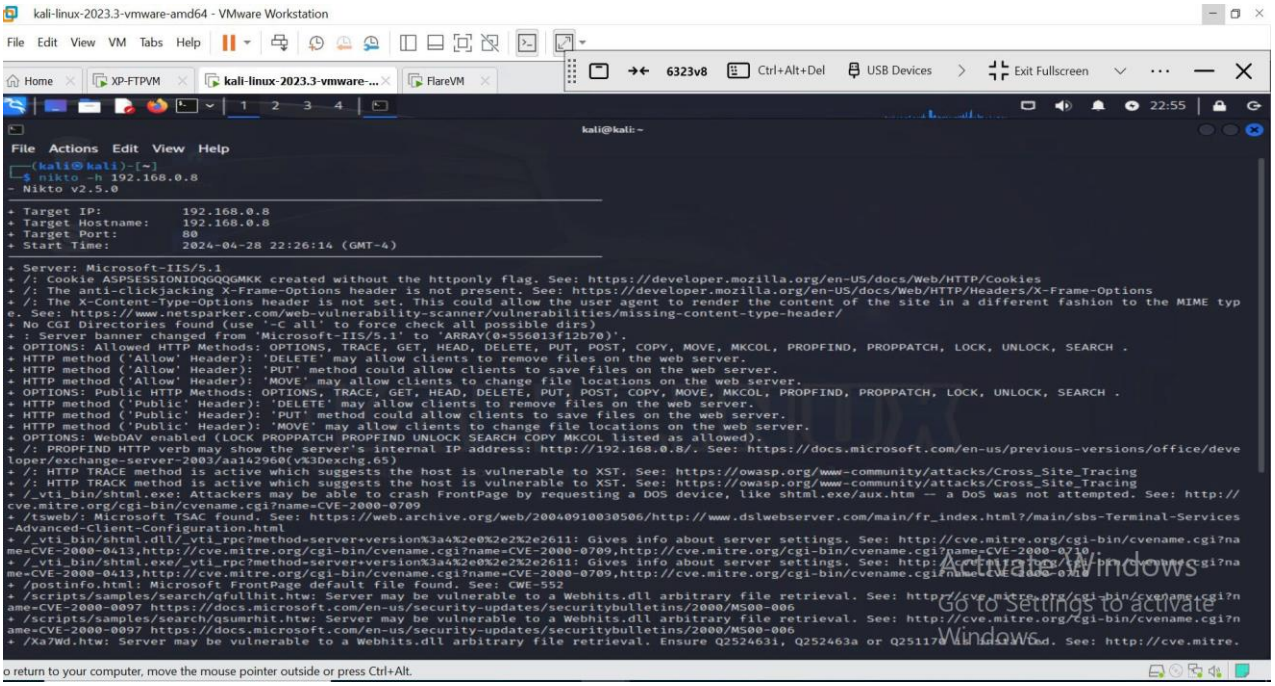
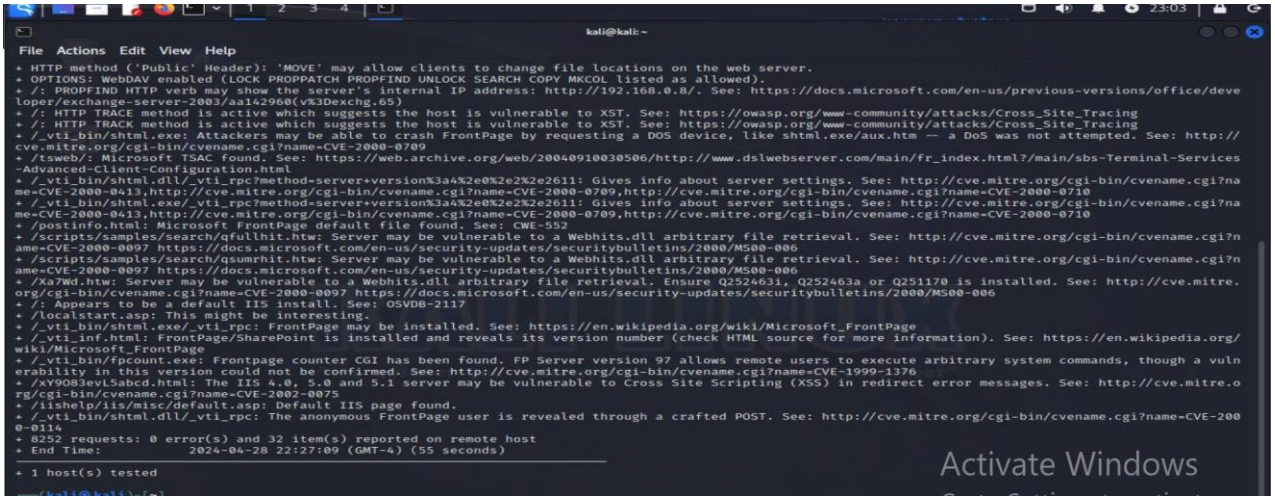


Figure B3. Nikto scan output identifying missing security headers, risky HTTP methods, WebDAV exposure, and Microsoft-IIS 5.1 weaknesses.



```
kali@kali: ~
File  Actions  Edit  View  Help
+ HTTP method ('Public' Header): 'MOVE' may allow clients to change file locations on the web server.
+ OPTIONS: WebDAV enabled (LOCK PROPPATCH PROPFIND UNLOCK SEARCH COPY MKCOL listed as allowed).
+ /: PROPFIND HTTP verb may show the server's internal IP address: http://192.168.0.8/. See: https://docs.microsoft.com/en-us/previous-versions/office/deve
loper/exchange-server-2003/aa142960(v%3Dexchg.65)
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /: HTTP TRACK method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /_vti_bin/shtml.exe: Attackers may be able to crash FrontPage by requesting a DOS device, like shtml.exe/aux.htm -- a DoS was not attempted. See: http://
cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0709
+ /tsweb/: Microsoft TSAC found. See: https://web.archive.org/web/20040910030506/http://www.dslwebserver.com/main/fr_index.html?/main/sbs-Terminal-Services
-Advanced-Client-Configuration.html
+ /_vti_bin/shtml.dll/_vti_rpc?method=server+version%3a4%2e0%2e2%2e2611: Gives info about server settings. See: http://cve.mitre.org/cgi-bin/cvename.cgi?na
me=CVE-2000-0413,http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0709,http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0710
+ /_vti_bin/shtml.exe/_vti_rpc?method=server+version%3a4%2e0%2e2%2e2611: Gives info about server settings. See: http://cve.mitre.org/cgi-bin/cvename.cgi?na
me=CVE-2000-0413,http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0709,http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0710
+ /postinfo.html: Microsoft FrontPage default file found. See: CWE-552
+ /scripts/samples/search/qfullhit.htw: Server may be vulnerable to a Webhits.dll arbitrary file retrieval. See: http://cve.mitre.org/cgi-bin/cvename.cgi?n
ame=CVE-2000-0097 https://docs.microsoft.com/en-us/security-updates/securitybulletins/2000/MS00-006
+ /scripts/samples/search/qsumrhit.htw: Server may be vulnerable to a Webhits.dll arbitrary file retrieval. See: http://cve.mitre.org/cgi-bin/cvename.cgi?n
ame=CVE-2000-0097 https://docs.microsoft.com/en-us/security-updates/securitybulletins/2000/MS00-006
+ /Xa7Wd.htw: Server may be vulnerable to a Webhits.dll arbitrary file retrieval. Ensure Q252463i, Q252463a or Q251170 is installed. See: http://cve.mitre.
org/cgi-bin/cvename.cgi?name=CVE-2000-0097 https://docs.microsoft.com/en-us/security-updates/securitybulletins/2000/MS00-006
+ /: Appears to be a default IIS install. See: OSVDB-2117
+ /localstart.asp: This might be interesting.
+ /_vti_bin/shtml.exe/_vti_rpc: FrontPage may be installed. See: https://en.wikipedia.org/wiki/Microsoft_FrontPage
+ /_vti_inf.html: FrontPage/SharePoint is installed and reveals its version number (check HTML source for more information). See: https://en.wikipedia.org/
wiki/Microsoft_FrontPage
+ /_vti_bin/fpcount.exe: Frontpage counter CGI has been found. FP Server version 97 allows remote users to execute arbitrary system commands, though a vuln
erability in this version could not be confirmed. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-1376
+ /xY9O83evL5abcd.html: The IIS 4.0, 5.0 and 5.1 server may be vulnerable to Cross Site Scripting (XSS) in redirect error messages. See: http://cve.mitre.o
rg/cgi-bin/cvename.cgi?name=CVE-2002-0075
+ /iishelp/iis/misc/default.asp: Default IIS page found.
+ /_vti_bin/shtml.dll/_vti_rpc: The anonymous FrontPage user is revealed through a crafted POST. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-200
0-0114
+ 8252 requests: 0 error(s) and 32 item(s) reported on remote host
+ End Time:           2024-04-28 22:27:09 (GMT-4) (55 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Figure B4. Nikto scan continuation showing legacy FrontPage artifacts, default IIS content, and multiple findings consistent with high-risk web server misconfiguration.